

Security Fundamentals · Section 3

Threats, Vulnerabilities, and Risk

By TOUCH DEN · November 11, 2026

Contents

What You Will Learn 1

Before You Start 1

1. The Three Words, Precisely 1

2. Where Vulnerabilities Come From 2

3. Threat Sources and Threat Events 2

4. Likelihood and Impact 3

5. Rating Risk: Qualitative and Quantitative 3

6. The Four Ways to Treat a Risk 4

7. Residual Risk 4

8. A Simple Risk Register 5

Common Mistakes 5

Summary 6

Check Your Understanding 6

Practice 7

What You Will Learn

- The precise difference between a threat, a vulnerability, and a risk.
- Where vulnerabilities come from.
- The kinds of threat source, and what a threat event is.
- How to think about likelihood and impact.
- How to rate risk, simply (qualitative) and with numbers (quantitative).
- The four ways to treat a risk, and what residual risk means.
- How to write a simple risk register.

Before You Start

Read lessons 1 and 2. Lesson 1 introduced these three words loosely; this lesson makes them precise and shows how professionals use them to decide what to fix. No programming or networking is needed.

---

1. The Three Words, Precisely

These three words are the working language of risk. Using them precisely is the mark of someone who understands security.

- A **threat** is something bad that could happen, or an actor who could cause it. Example: a criminal group that spreads ransomware.
- A **vulnerability** is a weakness that a threat can use. Example: staff who open email attachments without checking.
- A **risk** is the combination: the chance that a threat meets a matching vulnerability, and how bad the result would be. Example: the risk of a ransomware outbreak that stops the business for days.

A fourth word ties them together. When a threat actually uses a vulnerability, that event is sometimes called an **exploit** (as a verb, "to exploit a weakness"; as a noun, the tool or method used). The attacker's path is: a **threat** uses an **exploit** against a **vulnerability**, and the **risk** is how likely that is and how much it would hurt.

Why be so careful? Because each word points to a different fix. You cannot usually remove the threat (criminals exist), but you can often remove the **vulnerability** (train staff, filter email), and you can always try to reduce the **risk** (add a backup so the impact is smaller). Naming the right

one tells you where to act.

2. Where Vulnerabilities Come From

Vulnerabilities are weaknesses, and they come from everywhere a system is built and used:

Source	Example
Software bugs	A coding mistake that lets an attacker run their own commands
Misconfiguration	A database left open to the internet with no password
Weak design	A system that trusts whatever the user's app tells it
People	Falling for phishing; reusing passwords; propping a door open
Process	No one applies security updates; nobody reviews who has access
Physical	An unlocked server room; an unattended, unlocked laptop
Third parties	A weakness in a library, supplier, or contractor you rely on

Notice that most vulnerabilities are not exotic hacking tricks. They are ordinary gaps: an unpatched program, a weak password, a helpful employee. Published software weaknesses get a public ID called a ***CVE*** *(Common Vulnerabilities and Exposures), so that everyone can track and fix the same issue; lesson 10's frameworks and the Vulnerability Management course build on this.*

3. Threat Sources and Threat Events

It helps to split a threat into two parts: who or what could cause harm (the ***threat source****), and the thing they do (the* ***threat event****).*

Threat sources *fall into a few groups (lesson 4 covers them in depth):*

- ***Adversarial:*** *people who mean harm, from lone opportunists to criminal groups to nation-states.*
- ***Accidental:*** *a user who deletes the wrong file, an admin who misconfigures a server.*
- ***Structural:*** *equipment that fails, software that crashes, a disk that dies.*
- ***Environmental:*** *fire, flood, power loss, an earthquake.*

This is a useful reminder that not every threat is a hacker. A flood that destroys your only server breaks availability just as surely as an attacker, and a good risk assessment includes both.

A **threat event** is the specific thing that happens: "an attacker guesses a weak password", "a disk fails", "a flood reaches the server room". Risk assessment pairs a source with an event with a vulnerability, and asks how likely and how bad.

4. Likelihood and Impact

Every risk has two dimensions:

- **Likelihood:** how probable is it that this threat event happens and succeeds? This depends on how exposed the vulnerability is, how attractive the asset is, and how capable the threat source is.
- **Impact:** if it does happen, how bad is it? Measured in money, downtime, harm to people, legal trouble, and damage to reputation.

Keeping these two apart is important because they call for different responses. A **high-likelihood, low-impact** risk (a staff member mistypes an order) you might simply accept or fix cheaply. A **low-likelihood, high-impact** risk (a fire destroys the office) you handle with insurance and off-site backups, even though it rarely happens. The dangerous ones are **high-likelihood, high-impact** risks, and those you fix first.

> **Risk = likelihood × impact.**

This simple formula is the heart of all risk work. It is why you do not spend the same effort on everything: you rank risks by likelihood times impact, and start at the top.

5. Rating Risk: Qualitative and Quantitative

There are two ways to put numbers, or at least order, on risk.

Qualitative rating uses simple bands like Low, Medium, and High, often drawn as a grid of likelihood against impact:

	Low impact	**Medium impact**	**High impact**
High likelihood	Medium	High	High
Medium likelihood	Low	Medium	High
Low likelihood	Low	Low	Medium

You place each risk in a cell and deal with the High cells first. It is quick, needs no exact data, and is good enough for most small organizations. Its weakness is that "High" is a judgement, and two people may disagree.

Quantitative *rating uses real money. A classic method estimates the yearly cost of a risk:*

- ***SLE (Single Loss Expectancy):*** *the cost of one occurrence. A stolen laptop: $1,500 to replace and recover.*
- ***ARO (Annualized Rate of Occurrence):*** *how many times a year it is expected. Laptops stolen: 2 per year.*
- ***ALE (Annualized Loss Expectancy) = SLE × ARO.*** *$1,500 × 2 = $3,000 per year.*

Now you can compare: if a laptop-encryption and tracking program costs $1,000 a year and cuts the loss in half, it saves $1,500 for $1,000, so it is worth doing. Quantitative rating is powerful for big decisions, but the numbers are only estimates, so do not mistake the precision for certainty.

Most real work mixes the two: qualitative to sort quickly, quantitative for the big or expensive decisions.

6. The Four Ways to Treat a Risk

Once you have ranked a risk, you choose how to treat it. There are only four options.

Treatment	*Meaning*	*Example*
Reduce (mitigate)	*Add controls to lower the likelihood or impact*	*Train staff and filter email to cut phishing*
Transfer	*Make it someone else's cost, usually with insurance or a contract*	*Buy cyber-insurance for ransomware losses*
Avoid	*Stop doing the risky thing*	*Do not store card numbers at all; let a payment provider do it*
Accept	*Decide the risk is small enough to live with*	*Accept the rare mistyped order; it is cheap to fix*

Two notes. First, ***accepting*** *a risk is a real, legitimate choice, as long as it is a decision, made by someone with the authority, and not just ignoring the risk. Second, you often combine treatments: reduce a risk with controls, transfer what remains with insurance, and accept the small part left over.*

7. Residual Risk

No treatment removes a risk completely. What is left after you have applied your controls is called ***residual risk****.*

Suppose phishing is a High risk. You add training, an email filter, and multi-factor authentication. The likelihood drops a lot, but not to zero, someone may still click, and a filter may still miss a clever message. That remaining chance is the residual risk. The organization's leaders then decide, explicitly, whether the residual risk is acceptable. If it is, they accept it; if not, they add more controls.

This is why security is never "finished". You reduce risk to an acceptable level, accept what remains, and keep watching, because both the threats and the systems change over time.

8. A Simple Risk Register

*Organizations keep their risks in a **risk register**: a simple table that lists each risk, its rating, its treatment, and who owns it. Even a one-page register, kept up to date, puts a small business ahead of most. Here is a small example:*

#	Risk	Likelihood	Impact	Rating	Treatment	Owner
1	Ransomware via phishing	High	High	**High**	Reduce: training, email filter, offline backups	Manager
2	Laptop lost or stolen	Medium	Medium	**Medium**	Reduce: encryption, screen lock; Transfer: insurance	IT
3	Website down on a busy day	Medium	High	**High**	Reduce: extra capacity, monitoring	IT
4	Staff mistypes an order	High	Low	**Low**	Accept; easy to correct	Staff lead
5	Fire in the office	Low	High	**Medium**	Transfer: insurance; Reduce: off-site backups	Owner

The register turns a vague worry ("are we secure?") into a short list of specific decisions, each owned by a real person. That is the whole point of risk work: not to remove every risk, which is impossible, but to see the risks clearly and decide what to do about each one. The frameworks in lesson 10 are, in large part, organized ways of doing exactly this.

Common Mistakes

1. Using the three words loosely. *A threat, a vulnerability, and a risk are different, and each points to a different fix. Say which one you mean.*

2. Trying to remove threats. You usually cannot remove the threat (criminals, fires, and failures exist). You remove vulnerabilities and reduce risk.

3. Treating every risk equally. Rank by likelihood times impact, and start at the top. Spending equally on everything wastes effort on risks that do not matter.

4. Thinking only attackers are threats. Accidents, hardware failure, and nature break the CIA goals too, and belong in the risk assessment.

5. "Accepting" a risk by ignoring it. Accepting is a deliberate decision by someone with authority, recorded in the register, not simply forgetting about it.

6. Believing security is ever finished. Residual risk always remains, and systems and threats change. Risk work is ongoing.

Summary

Term	Remember
Threat	A bad thing that could happen, or an actor who could cause it
Vulnerability	A weakness a threat can use
Risk	Likelihood × impact of a threat meeting a vulnerability
Threat source / event	Who or what causes harm / the specific thing that happens
Likelihood and impact	How probable, and how bad; keep them apart
Qualitative / quantitative	Low-Med-High bands / money estimates (SLE, ARO, ALE)
Four treatments	Reduce, Transfer, Avoid, Accept
Residual risk	What is left after controls; it must be accepted on purpose
Risk register	A table of risks, ratings, treatments, and owners

Check Your Understanding

1. In one sentence each, define threat, vulnerability, and risk.
2. Give the two parts of the risk formula.
3. Name the four threat-source groups, and give an example of a non-attacker threat.
4. A disk fails on average once every five years, and each failure costs $2,000 to recover. What is the ALE?
5. What are the four ways to treat a risk? Give an example of each.
6. What is residual risk, and who should decide whether to accept it?

7. *What is a risk register, and why is even a simple one useful?*

Answers

1. *A threat is a bad thing that could happen (or an actor who could cause it); a vulnerability is a weakness a threat can use; a risk is the likelihood and impact of the two meeting.*
2. *Risk = likelihood × impact.*
3. *Adversarial, accidental, structural, and environmental. A non-attacker example: a flood or fire (environmental), or a failed disk (structural).*
4. *ARO = 1/5 = 0.2 per year; SLE = $2,000; ALE = 0.2 × $2,000 = $400 per year.*
5. *Reduce (add controls, e.g. training), Transfer (insurance), Avoid (stop doing the risky thing, e.g. don't store card numbers), Accept (live with a small risk, e.g. a rare mistyped order).*
6. *The risk that remains after controls are applied. Someone with authority (a manager or owner) decides, explicitly, whether to accept it.*
7. *A table listing each risk with its rating, treatment, and owner. Even a simple one turns a vague worry into a short list of specific, owned decisions.*

Practice

Think of a small organization you know: a shop, a clinic, a school club, or your own home network.

1. *Write down three risks it faces. For each, name the **threat** and the **vulnerability** separately.*
2. *Give each risk a qualitative rating (Low, Medium, or High) using likelihood and impact.*
3. *Choose one of the four treatments for each, and say who should own it.*

Put your answers in a small five-column table: risk, threat, vulnerability, rating, treatment. You have just written a risk register.

A Worked Example

For a home network:

Risk	Threat	Vulnerability	Rating	Treatment
Wi-Fi password guessed	A neighbour or passer-by	A short, default Wi-Fi password	Medium	Reduce: set a long password
Phone lost with banking app	Theft or loss	No screen lock; app stays signed in	High	Reduce: screen lock + app PIN
Old router never updated	An attacker using a known bug	Firmware years out of date	Medium	Reduce: update, or replace the router

Course mark icon from Material Symbols by Google, Apache License 2.0. NIST, CIS, ISO, OWASP, and MITRE ATT&CK are the trademarks of their respective owners, used here only to refer to their published work.